

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain H – Resilience, Continuity

Table of Contents

Domain H - Resilience, Continuity, and Recovery	4
H1. Continuity Planning Agent	4
Agent Blueprint [Informative]	4
Technical Implementation Details (H1) [Informative]	18
MCP-Native Protocol Specification (H1) [Normative]	20
H2. DR Orchestration Agent	21
Agent Blueprint [Informative]	21
Technical Implementation Details (H2) [Informative]	34
MCP-Native Protocol Specification (H2) [Normative]	36
H3. Resilience Engineering Agent	37
Agent Blueprint [Informative]	37
Technical Implementation Details (H3) [Informative]	52
MCP-Native Protocol Specification (H3) [Normative]	54
H4. Failover Automation Agent	55
Agent Blueprint [Informative]	55
Technical Implementation Details (H4) [Informative]	67
MCP-Native Protocol Specification (H4) [Normative]	70
H5. Immutable Backup Agent	71
Agent Blueprint [Informative]	71
Technical Implementation Details (H5) [Informative]	84
MCP-Native Protocol Specification (H5) [Normative]	86

Domain H - Resilience, Continuity, and Recovery

H1. Continuity Planning Agent

Agent Blueprint [Informative]

Purpose: Maintain and update Business Continuity Plans (BCPs) from authoritative business-process inventories and impact assessments; ensure traceability to risk assessments and legal/regulatory requirements; emit BCPUpdate artifacts and events.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **BCM/GRC REST — Process inventory & BIAs:** RTO, RPO, MTPD, dependencies (apps, third parties, sites), ownership, assessment dates.
- **Impact Assessment Questionnaires — JSON/CSV:** owner-attested deltas (RTO/RPO changes, new risks, contacts).
- **Risk Register REST:** linked risks (severity, residual, treatments, compensating controls).
- **Regulatory/Standards Feeds — HTTP/JSON/RSS:** continuity obligations (ISO 22301, NIST 800-53 CP family, NIST 800-34), cross-mappings and updates.

Model training / knowledge (what the LLM relies on):

- Style/policy prompt pack for BCP structure, terminology, and acceptance rubric (ISO 22301, NIST 800-34/800-53 CP mappings).
- RAG indices over process inventory, prior BCPs, drill reports, and control catalogs; do **not** train on regulated/contractual documents—fetch by evidence_refs.
- Guardrails: write access only to BCP repos/BCM records; deny any production failover actions; scoped tokens for Git/BCM/Risk APIs.

Decisions it makes (deterministic + model-assisted):

- **Plan synthesis/update** when BIA or owner-submitted deltas change RTO/RPO/dependencies beyond thresholds.
- **Traceability completeness** (BCP section ↔ process ↔ risk ↔ control/obligation); compute gaps and severity.
- **Classification choice** (C2 default; elevate to C3 if contracts/PII embedded in plan artifacts).

- **Publish gating:** require owner approval if `change_risk >= 0.6` or if critical dependencies are added/removed.
- **Notification routing:** emit `BCPUpdate` event; open tickets for unresolved gaps; trigger (non-prod) drill scheduling hooks when policy permits.

Routing / where outputs go:

- **BCP updates** → Git PR against BCP repo **and/or** BCM/GRC record updates with attachments (diffs, `evidence_refs`).
- **BCPUpdate events** → Kafka/AMQP topic for governance dashboards and downstream analytics.
- **Tickets/alerts** → GRC/ITSM if traceability gaps or SLO breaches are detected.

Automation scope vs. manual/HITL:

- Fully automated: ingest inventories/BIAs; synthesize draft BCP; build traceability matrix; open PR/update BCM record; emit event.
- **HITL required:** approve changes that tighten/relax RTO/RPO beyond policy thresholds; any elevation to C3; acceptance of third-party dependency substitutions.
- Manual outside agent: conduct/live drills; executive sign-off; cross-org resourcing commitments.

Security Domain: Resilience, Continuity, and Recovery

Inputs (native protocols consumed) [Informative]

1. **BCM/GRC REST** — business process inventory & BIA results (e.g., Archer BCM, ServiceNow BCM).
2. **Impact Assessment Questionnaires (JSON/CSV over HTTPS)** — periodic BIA/RA updates from process owners.
3. **Risk Register REST** — linked enterprise risks (treatments, residual risk, compensating controls).
4. **Regulatory/Standards Feeds (HTTP/JSON/RSS)** — continuity obligations and mappings (ISO 22301, NIST 800-53 CP).

Example: Consumed Protocol — BCM/GRC REST (Process Inventory & BIA)

[Informative]

Native payload

```
{
  "process_id": "BIZ-PAY-AP-001",
  "name": "Accounts Payable",
  "owner_group": "finance.ops",
  "rto_minutes": 240,
  "rpo_minutes": 60,
  "mtpd_minutes": 1440,
  "dependencies": {
    "applications": ["erp-ap", "idp", "email"],
    "third_parties": ["BankXYZ", "TaxCalcCo"]
  },
  "sites": ["nyc-hq", "va-dc1"],
  "last_assessed": "2025-08-10T14:20:00Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h1-bcm-1111-2222-3333-4444",
    "thread_id": "uuid-bia-BIZ-PAY-AP-001",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "ContinuityPlanningAgent",
    "intent": "plan",
    "policy_refs": ["CP-2", "CP-7", "CP-8", "CP-9"],
    "decision_basis": {
      "evidence_refs": ["uri://bcm/bia/BIZ-PAY-AP-001@2025-08-10"],
      "confidence": 0.98,
    }
  }
}
```

```

    "explanation_ref": "uri://kb/bcm/bia-to-bcp-synthesis"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/resilience/continuity-planning-agent",
    "signing_kid": "kid-bcm-h1-01",
    "attestation_ref": "uri://slsa/attestations/continuity-planning@sha256:bcm01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Impact Assessment Questionnaires (JSON/CSV)

[Informative]

Native payload

```

{
  "process_id": "BIZ-PAY-AP-001",
  "assessment_id": "BIA-2025Q3-AP",
  "impact_changes": { "rto_minutes": 180, "rpo_minutes": 30 },
  "new_risks": ["Loss of primary bank API connectivity"],
  "contact_updates": { "primary": "ap.manager", "backup": "fin.dir" },
  "submitted_at": "2025-08-12T16:05:00Z",
  "submitter": "ap.manager"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {

```

```

"mcp_version": "0.9",
"mission_id": "uuid-h1-imp-5555-6666-7777-8888",
"thread_id": "uuid-assess-BIA-2025Q3-AP",
"task_id": "uuid-9911-8822-7733-6644",
"role": "ContinuityPlanningAgent",
"intent": "plan",
"policy_refs": ["CP-2", "CP-7"],
"decision_basis": {
  "evidence_refs": ["uri://bcm/assessments/BIA-2025Q3-AP"],
  "confidence": 0.93,
  "explanation_ref": "uri://kb/bcm/owner-attestations"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/resilience/continuity-planning-agent",
  "signing_kid": "kid-imp-h1-02",
  "attestation_ref": "uri://slsa/attestations/continuity-planning@sha256:imp02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Risk Register REST [Informative]

Native payload

```

{
  "process_id": "BIZ-PAY-AP-001",
  "linked_risks": [

```

```

    {"risk_id": "RISK-2025-0410-07", "title": "Bank API outage", "severity": "High",
"residual": "Medium"},
    {"risk_id": "RISK-2025-0301-11", "title": "Email provider disruption", "severity":
"Medium", "residual": "Low"}
],
"last_synced": "2025-08-13T10:40:00Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h1-risk-3333-4444-5555-6666",
    "thread_id": "uuid-risklinks-BIZ-PAY-AP-001",
    "task_id": "uuid-4411-5522-6633-7744",
    "role": "ContinuityPlanningAgent",
    "intent": "plan",
    "policy_refs": ["CP-2", "PM-9"],
    "decision_basis": {
      "evidence_refs": ["uri://risk/register/links/BIZ-PAY-AP-001@2025-08-13"],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/bcm/risk-to-bcp-mapping"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/resilience/continuity-planning-agent",
      "signing_kid": "kid-risk-h1-03",
      "attestation_ref": "uri://slsa/attestations/continuity-planning@sha256:risk03"
    },
  },
}

```

```
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}
```

Example: Consumed Protocol — Regulatory/Standards Feeds [Informative]

Native payload

```
{
  "source": "ISO 22301:2019",
  "section": "8.4.3",
  "requirement": "BCP shall include recovery procedures and roles with tested
RTO/RPO.",
  "update_id": "ISO22301-843-2025-08-01",
  "published": "2025-08-01T12:00:00Z",
  "mapping": ["NIST 800-53 CP-2", "NIST 800-34"]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h1-stds-7777-8888-9999-0000",
    "thread_id": "uuid-iso22301-8.4.3-2025-08-01",
    "task_id": "uuid-abcd-ef01-2345-6789",
    "role": "ContinuityPlanningAgent",
    "intent": "plan",
    "policy_refs": ["CP-1", "CP-2", "CP-9"],
    "decision_basis": {
```

```

    "evidence_refs": ["uri://standards/iso22301/updates/ISO22301-843-2025-08-01"],
    "confidence": 0.9,
    "explanation_ref": "uri://kb/bcm/standards-mapping"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/resilience/continuity-planning-agent",
    "signing_kid": "kid-stds-h1-04",
    "attestation_ref": "uri://slsa/attestations/continuity-planning@sha256:stds04"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **BCPUpdate** via Git over HTTPS/SSH (PR against BCP repo) and/or BCM/GRC REST (update records, attach evidence).
- **BCPUpdate event** via Kafka/AMQP for governance dashboards.

MCP context (required) [Informative]

mission_id; role="ContinuityPlanningAgent"; intent="plan"; policy_refs (e.g., CP-1, CP-2, CP-7, CP-9, CP-10); decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID, signing key, attestation)

MCP context (optional) [Informative]

classification (typically C2; C3 if contracts/PII are embedded); constraints (e.g., "review_required:true", "no_prod_disruption"); legal_hold (true when plans are part of regulatory inquiry)

Enforcement note [Informative]

PEPs for dashboards/BCM writes must verify **provenance.attestation** and honor **constraints** (e.g., review_required). No production automation (failover/drills) may be triggered from this agent's outputs.

NIST SP 800-160v2 linkage [Informative]

Develop/Maintain — continuity capabilities with traceable evidence and governance.

Automation feasibility [Informative]

High (inventory/BIA ingestion, plan synthesis, control/obligation mapping). **Owner approval required before publish.**

Output Contracts (merged) [Informative]

OC-1: BCPUpdatePublish (Git PR or BCM/GRC Record Update) [Informative]

- **Producer(s):** H1
- **Topic/Path:** repo=bcps//<process_id> (branch=main) **or** bcm://records/<process_id>
- **Schema/Format:** BCP document bundle (Markdown/Asciidoc + JSON traceability matrix); attachments include evidence_refs and diffs
- **Classification:** C2 default; C3 if contracts/PII embedded
- **Delivery:** at-least-once
- **Ordering:** per-process_id
- **Idempotency-Key:** sha256(process_id, bcp_version)
- **Ack/Nack:** Git commit/PR# or BCM record 200/201 is ACK; NACK is HTTP 4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; on failure open ITSM ticket and halt publish
- **Side-Effects:** update BCP index; link artifacts in evidence store; notify owner_group
- **HITL Token:** required when rto_delta_minutes > theta_rto or rpo_delta_minutes > theta_rpo or classification=C3
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation

- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=BCPUpdatePublish@1.0 | json_schema_uri=uri://schema/bcp-update-publish-1.0.json | sha256= | producers=H1 | consumers=BCM-01, BCP-Repo-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: BCPUpdateEvent (Kafka/AMQP) [Informative]

- **Producer(s):** H1
- **Topic/Path:** resilience.bcp.update
- **Schema/Format:** BCPUpdateEvent@1.0 (process_id, version, change_summary, rto/rpo deltas, risk_links, evidence_refs)
- **Classification:** C1 (metadata only) or C2 if includes sensitive dependency details
- **Delivery:** at-least-once
- **Ordering:** per-process_id
- **Idempotency-Key:** sha256(process_id, bcp_version, change_hash)
- **Ack/Nack:** broker ACK<=5s; retry/backoff on NACK
- **Side-Effects:** update governance dashboards; trigger non-prod drill scheduler if enabled
- **HITL Token:** none (metadata only)
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.summary_ref
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When governance dashboards/event consumers are present

schema_id=BCPUpdateEvent@1.0 | json_schema_uri=uri://schema/bcp-update-event-1.0.json | sha256= | producers=H1 | consumers=GovDash-01, DataLake-01 |

accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: BCPDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** H1, Legal-Portal-01, Compliance-Portal-01
- **Topic/Path:** resilience.bcp.contestation
- **Schema/Format:** BCPDispute@1.0
(issue_type={RTO,RPO,Dependency,Scope}, rationale_url)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-process_id
- **Idempotency-Key:** sha256(process_id, dispute_id)
- **Ack/Nack:** case_id assigned in <=30s else retry/backoff
- **Side-Effects:** freeze related publishes if severity high; open legal/compliance workflow
- **HITL Token:** required when severity >= high
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=BCPDispute@1.0 | json_schema_uri=uri://schema/bcp-dispute-1.0.json |
producers=H1, Legal-Portal-01 | consumers=Legal-01, Compliance-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

OC-4: IRContinuityViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** H1
- **Topic/Path:** resilience.bcp.incident
- **Schema/Format:** IRContinuityViolationEvent@1.0 (observed_rto/rpo, breach=true/false, impacted_processes)

- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident-id
- **Idempotency-Key:** sha256(incident_id, process_id)
- **Ack/Nack:** SIEM/CaseID assigned in <=30s; retry/backoff
- **Side-Effects:** open SOAR case; attach latest BCPUpdate and traceability matrix
- **Observability:** trace_id, mission_id, policy_refs, incident_id
- **Retention/TTL:** per IR policy (>=1 year)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRContinuityViolationEvent@1.0 | json_schema_uri=uri://schema/ir-continuity-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: ContinuityChangeImpactReport (BIA/BCP Drift Management) [Informative, optional]

- **Producer(s):** H1 (pre-publish)
- **Topic/Path:** resilience.bcp.change_impact
- **Schema/Format:** ContinuityChangeImpactReport@1.0 (change_impact_score, rto/rpo deltas, dependency churn)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-change_id
- **Idempotency-Key:** sha256(process_id, change_id)
- **Ack/Nack:** PR comment/reference created or BCM note ACK; retry/backoff
- **Side-Effects:** gate to staging/production per thresholds
- **Observability:** trace_id, mission_id, policy_refs, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When change impact scoring is enabled

schema_id=ContinuityChangeImpactReport@1.0 |
json_schema_uri=uri://schema/continuity-change-impact-1.0.json
Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; H1 (aggregation)
- **Topic/Path:** resilience.bcp.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
(labels={helpful|neutral|harmful})
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, artifact_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, artifact_id, labels
- **Retention/TTL:** 1 year (or per HR/Legal)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_inventory, ingesting_assessments, synthesizing_bcp, diffing, publishing, notifying, contestation_workflow, failed, closed }
transition(idle -> ingesting_inventory) when new BIA or standards update arrives
transition(ingesting_inventory -> synthesizing_bcp) when required fields present
transition(synthesizing_bcp -> diffing) when draft built
transition(diffing -> publishing) when gaps <= threshold AND approvals present
transition(publishing -> notifying) on successful ACK

transition(any -> contestation_workflow) when BCPDispute opens or
 stakeholder_disagreement_score >= 0.5
 transition(* -> failed) on validation error or timeout
 timeout(publishing, 60s) -> failed; retry <= 5 with exp backoff
 idempotency_key = sha256(process_id, bcp_version) for publish; sha256(process_id,
 bcp_version, change_hash) for event

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 BCPUpdatePublish	Required	Always	Authoritative BCP distribution
OC-2 BCPUpdateEvent	Conditionally Required	Governance dashboards/event consumers present	Visibility & analytics
OC-3 BCPDispute	Optional	Contestability enabled	Governance/appeals workflow
OC-4 IRContinuityViolationEvent	Optional	IR/SIEM integration present	Incident response & forensics
OC-5 ContinuityChangeImpactReport	Conditionally Required	Change impact scoring enabled	Risk-aware change management
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- `policy_refs`: CP-1, CP-2, CP-7, CP-9, CP-10 (plus ISO 22301 sections as applicable)
- **HITL required**: `rto_delta_minutes > theta_rto`; `rpo_delta_minutes > theta_rpo`; `classification=C3`; substitution of critical third-party dependencies
- **Automatic HITL escalation triggers**: `model_confidence < theta_low`; `model_drift_detected = true`; `stakeholder_disagreement_score >= 0.5`
- **Manual outside agent**: drill execution; executive approval; contractual renegotiations

SLOs and KPIs [Informative]

- `BCPPublishAck_p95 <= 60 s`
- `BCPStalenessRate_30d <= 2 percent` (no plan older than policy threshold)
- `TraceabilityPassRate >= 98 percent` (sections ↔ risks ↔ controls/obligations)
- `DrillCoverage_Quarter >= 90 percent` of in-scope processes
- `FalseElevateToC3Rate_30d <= 1 percent`

Outputs index [Informative]

[OC-1 BCPUpdatePublish], [OC-2 BCPUpdateEvent], [OC-3 BCPDispute], [OC-4 IRContinuityViolationEvent], [OC-5 ContinuityChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (H1) [Informative]

Model and training profile [Informative]

`model_id=continuity-text-model`; `temperature=0.1`; `max_tokens_out=900`
`prompt_pack_id=continuity-bcp-v1` (structure rubric, mapping rules, examples)
RAG: `sources={BCP repo, BCM inventory, risk register, standards index}`;
`max_docs=10`; `min_similarity=0.78`; citations required
`fine_tuning/adapters`: none initially; if added, exclude contractual/PII artifacts; eval on rubric compliance + hallucination bounds
`guardrails`: allowlist for BCP repo paths and BCM endpoints; deny any prod-action tools

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (BIAs, deltas, drafts, approvals), ttl=365d
semantic_memory: namespaces=["bcps","bia","risks","standards"]; embeddings=text-embedding-sec-v1; k=10
durable_state_store: event-sourced journal; snapshot each published version
consistency: at-least-once (publish/event)
idempotency: per Output Contracts

Decision and routing logic [Informative]

$$\text{change_risk} = 0.35\text{criticality} + 0.25(\text{rto_delta_norm}) + 0.2*(\text{rpo_delta_norm}) + 0.2*\text{dependency_churn}$$
$$\text{rto_delta_norm} = \text{abs}(\text{new_rto} - \text{old_rto}) / \text{max}(\text{old_rto}, 1)$$
$$\text{rpo_delta_norm} = \text{abs}(\text{new_rpo} - \text{old_rpo}) / \text{max}(\text{old_rpo}, 1)$$
$$\text{dependency_churn} = (\text{added_dependencies} + \text{removed_dependencies}) / \text{max}(\text{previous_dependencies}, 1)$$
$$\text{publish_allowed} = (\text{traceability_gaps} == 0) \text{ and } (\text{owner_approval} == \text{true} \text{ or } \text{change_risk} < 0.6)$$

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial, jailbreak]
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly ATT&CK/D3FEND-inspired probes (prompt injection targeting obligation mappings)
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs; risk_links;
obligation_mappings; hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; retention per classification and legal_hold

Incident Response Integration [Informative]

on IR event indicating RTO/RPO breach → emit IRContinuityViolationEvent (OC-4), attach latest BCP and deltas

Change Impact Assessment [Informative]

compute change_risk and dependency_churn; emit ContinuityChangeImpactReport (OC-5) before publish; gate per thresholds

Stakeholder Feedback Loop [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

emit FeedbackIngestionEvent (OC-6); governance-reviewed updates may adjust prompt_pack or rubric (no auto-training on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress
legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: BCM/GRC REST; Impact Questionnaire HTTPS; Risk Register REST; Regulatory/Standards Feeds

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as used)

Safety and abuse prevention [Informative]

kill_switch on provenance/signature mismatch; sandbox mode when constraints include "review_required:true"

blast_radius caps: max 3 critical-process BCP updates/day without executive approval
cost/QPS limits per mission_id; alerts on breach

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of historical BIAs; red-team mapping/traceability attacks; drift checks and rollback

Deployment and lifecycle [Informative]

scaling/HPA by queue depth; canary PRs to non-prod repo; auto-rollback on validation failures; SBOM + attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-34; NIST SP 800-53 Rev. 5 (CP family); ISO 22301:2019; NIST CSF 2.0; MITRE D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (H1) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** BCM/GRC REST; Impact Questionnaire HTTPS (JSON/CSV); Risk Register REST; Regulatory/Standards Feeds (HTTP/JSON/RSS)

- **Native Protocol(s) Produced:** BCPUpdatePublish (Git PR or BCM/GRC record update); BCPUpdateEvent (Kafka/AMQP)
- **MCP Context Fields:**
 - **Required:** mission_id; role="ContinuityPlanningAgent"; intent="plan"; policy_refs=[CP-1, CP-2, CP-7, CP-9, CP-10]; decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID, signing key, attestation)
 - **Optional:** classification; constraints; legal_hold
- **Enforcement Note:** PEPs must verify provenance.attestation and respect constraints; production failover/drill actions are out of scope for this agent.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** native and MCP-wrapped (authoritative) as shown above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

H2. DR Orchestration Agent

Agent Blueprint [Informative]

Purpose: Trigger and coordinate disaster recovery (DR) failovers and restores across regions/sites; execute DR test plans; record outcomes with full rollback traceability.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **DR Test Plans (Git/REST):** versioned runbooks/playbooks (YAML/JSON) with prechecks, failover and rollback steps, owners, approvals, evidence store paths, RTO/RPO targets.
- **Outage Alerts (Monitoring/Incident Webhooks / OTel / PagerDuty-like REST):** declared outages, SLO breaches, region/service, severity, timestamps, references to metrics/incidents.

Model training / knowledge (what the LLM relies on):

- Prompt pack: DR orchestration rubric (plan-parsing patterns, precheck semantics, safety gates, rollback-first principles).
- RAG: plan repository history, prior DR reports, incident postmortems, services/regions inventory; never train on customer data—always dereference via `evidence_refs`.
- Guardrails: read-only on monitoring; constrained function-calling to plan parsing and result reporting; **no direct production changes** via this card (cloud/infra calls referenced in plans are executed by out-of-band orchestrators/PEPs).

Decisions it makes (deterministic + model-assisted):

- **Trigger eligibility:** evaluate alert + plan preconditions; compute `failover_trigger_score`; require approvals when in production.
- **Step orchestration:** order/parallelize plan steps; insert waits/health verifications; enforce timeouts.
- **Rollback policy:** initiate rollback when health does not converge or on explicit HITL/IR command; ensure evidence-linked traceability.
- **Test vs. production mode:** enforce `constraints.test_mode` for drills; in production, elevate `legal_hold` as required.

Routing / where outputs go:

- **Step outcomes** → `DRActionOutcome` events (Kafka/AMQP/REST) with timestamps, step ids, success/failure, evidence URIs.
- **Run summary** → optional `DRRunReport` artifact (Git PR note or REST record) with RTO/RPO attainment and rollback lineage.
- **Tickets/alerts** → link/report to incident tracker; open tasks for failed steps or missing approvals.

Automation scope vs. manual/HITL:

- Fully automated: parse plans; correlate alerts to plans; drive step execution through orchestrators; emit step outcomes; produce run summaries.
- **HITL required:** initiating production failover; bypassing failed prechecks; declaring success with unmet SLOs; performing cross-region DNS cutover.
- Manual outside agent: business approval to operate in degraded mode; executive comms; customer notification.

Security Domain: Resilience, Continuity, and Recovery

Inputs (native protocols consumed) [Informative]

1. **DR Test Plans (Git/REST)** — versioned runbooks & playbooks (YAML/JSON).
2. **Outage Alerts (Monitoring/Incident Webhooks / OTel / PagerDuty-like REST)**
— declared outages, SLO breaches.

Example: Consumed Protocol — DR Test Plans (Git/REST) [Informative]

Native payload (YAML runbook)

plan_id: DR-PLAN-PAYMENTS-REGIONAL

version: "2025.08.10"

service: "payments-api"

rto_minutes: 60

rpo_minutes: 5

scope:

primary_region: us-east-1

dr_region: us-west-2

prechecks:

- id: dns-health

action: "check_route53_healthcheck hc-payments"

- id: db-lag

action: "check_aurora_replica_lag <= 300s"

failover_steps:

- id: promote-db

action: "promote_aurora_cluster arn:aws:rds:us-west-2:....:cluster/payments-dr"

- id: switch-dns

action: "update_route53_record payments.example.com -> alb-dr"

- id: scale-api

action: "asg_set_desired asg-payments-dr 12"

rollback:

- id: revert-dns

- action: "update_route53_record payments.example.com -> alb-primary"

- id: demote-db

- action: "promote_aurora_cluster arn:aws:rds:us-east-1:....:cluster/payments-primary"

test_mode: false

evidence:

- store: "s3://dr-evidence/payments-api/"

owners:

- "payments.sre"

approvals_required: ["CAB-DR", "CIO"]

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h2-dr-1111-2222-3333-4444",
    "thread_id": "uuid-plan-DR-PLAN-PAYMENTS-REGIONAL",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "DROrchestrationAgent",
    "intent": "recover",
    "constraints": ["region:primary"],
    "policy_refs": ["CP-2", "CP-7", "CP-10"],
    "rollback_procedures_ref": "uri://git/dr/runbooks/DR-PLAN-PAYMENTS-REGIONAL#rollback",
    "decision_basis": {
      "evidence_refs": ["uri://git/dr/runbooks/DR-PLAN-PAYMENTS-REGIONAL@2025.08.10"],
```

```

    "confidence": 0.98,
    "explanation_ref": "uri:///kb/dr/orchestration-flow#payments-api"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/resilience/dr-orchestration-agent",
    "signing_kid": "kid-drplan-h2-01",
    "attestation_ref": "uri:///slsa/attestations/dr-orchestration@sha256:plan01"
  },
  "classification": "C2",
  "legal_hold": false
},
  "native_payload": "plan_id: DR-PLAN-PAYMENTS-REGIONAL\\nversion:
\\\"2025.08.10\\\" ... (elided) ..."
}

```

Example: Consumed Protocol — Outage Alerts (Monitoring/Incident / OTel)

[Informative]

Native payload (incident webhook)

```

{
  "incident_id": "INC-DR-2025-0815-0041",
  "service": "payments-api",
  "severity": "SEV-1",
  "region": "us-east-1",
  "symptoms": ["500_rate_spike", "healthcheck_fail"],
  "slo_breach": true,
  "started_at": "2025-08-15T13:05:10Z",
  "current_status": "investigating",
  "references": [
    "uri:///otel/metrics/payments-api/availability/2025-08-15T13:05Z",

```

```

    "uri://pagerduty/incidents/INC-DR-2025-0815-0041"
  ]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h2-dr-1111-2222-3333-4444",
    "thread_id": "uuid-incident-INC-DR-2025-0815-0041",
    "task_id": "uuid-55aa-66bb-77cc-88dd",
    "role": "DROrchestrationAgent",
    "intent": "recover",
    "constraints": ["region:primary"],
    "policy_refs": ["CP-10", "IR-4"],
    "decision_basis": {
      "evidence_refs": [
        "uri://pagerduty/incidents/INC-DR-2025-0815-0041",
        "uri://otel/metrics/payments-api/availability/2025-08-15T13:05Z"
      ],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/dr/failover-triggers#slo-breach-sev1"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/resilience/dr-orchestration-agent",
      "signing_kid": "kid-incident-h2-02",
      "attestation_ref": "uri://slsa/attestations/dr-orchestration@sha256:incident02"
    },
  },
}

```

```

    "classification": "C2",
    "legal_hold": true
  },
  "native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **DRActionOutcome** events (Kafka/AMQP/REST) — stepwise results, timestamps, evidence URIs.
- **DRRunReport** (optional) — signed summary (RTO/RPO attainment, pass/fail, rollback lineage) stored as Git PR note or REST record.

MCP context (required) [Informative]

mission_id; role="DROrchestrationAgent"; intent="recover";
 constraints=["region:primary"]; decision_basis (evidence_refs to plan + alert;
 confidence; explanation_ref); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (often C2; C3 if customer/contract data present); legal_hold (true when DR invoked during a major incident); rollback_procedures_ref (URI to tested rollback runbook)

Enforcement note [Informative]

Out-of-band orchestrators/PEPs MUST verify provenance.attestation and honor constraints; production cutovers require HITL approval and CAB/IR gates.

NIST SP 800-160v2 linkage [Informative]

Maintain & Recover — assured restoration and reconstitution with verifiable artifacts and rollback traceability.

Automation feasibility [Informative]

High (end-to-end orchestration/test execution automatable; change gates may require HITL).

Output Contracts (merged) [Informative]

OC-1: DRActionOutcome (Stepwise Result Event) [Informative]

- **Producer(s):** H2
- **Topic/Path:** resilience.dr.action_outcome (Kafka/AMQP) or POST /dr/outcomes (REST)
- **Schema/Format:** DRActionOutcome@1.0 (mission_id, plan_id, run_id, step_id, step_type, started_at, ended_at, status, evidence_refs, region, test_mode)
- **Classification:** C1 (metadata) or C2 if evidence contains sensitive infra details
- **Delivery:** at-least-once
- **Ordering:** per run_id then step_id
- **Idempotency-Key:** sha256(run_id, step_id, status)
- **Ack/Nack:** broker ACK<=5s or REST 202; NACK=4xx/5xx
- **Timeouts/Retry:** exp-backoff<=5x; on repeated NACK raise ticket and pause subsequent steps (safe hold)
- **Side-Effects:** append to tamper-evident audit journal; notify incident thread
- **HITL Token:** none (reporting only)
- **Observability:** trace_id, mission_id, plan_id, run_id, step_id, classification_label, provenance.attestation
- **Retention/TTL:** 1 year (tests) / 7 years (production incidents)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=DRActionOutcome@1.0 | json_schema_uri=uri://schema/dr-action-outcome-1.0.json | sha256= | producers=H2 | consumers=GovDash-01, IR-Case-01, DataLake-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: DRRunReport (Signed Summary) [Informative]

- **Producer(s):** H2
- **Topic/Path:** repo=dr/reports//<run_id>.md (Git) or dr://reports/<run_id> (REST)
- **Schema/Format:** DRRunReport@1.0 (rto_target, rto_actual, rpo_target, rpo_actual, pass/fail, rollback_lineage, approvals, evidence_refs)

- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per run_id
- **Idempotency-Key:** sha256(run_id, report_digest)
- **Ack/Nack:** PR/commit or REST 201 is ACK; NACK=4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; on failure open IR/ITSM task
- **Side-Effects:** link report to incident; update DR dashboard KPI tiles
- **HITL Token:** required to mark production run as “pass” when rto_actual > rto_target
- **Observability:** trace_id, mission_id, plan_id, run_id, policy_refs, decision_basis.summary_ref
- **Retention/TTL:** 7 years (production) / 2 years (tests)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When DR tests are executed or when production runs require signed summaries

schema_id=DRRunReport@1.0 | json_schema_uri=uri://schema/dr-run-report-1.0.json | sha256= | producers=H2 | consumers=Audit-01, GovDash-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: DRContestation (Explainability & Appeals) [Informative, optional]

- **Producer(s):** H2, Legal-Portal-01, Compliance-Portal-01
- **Topic/Path:** resilience.dr.contestation
- **Schema/Format:** DRContestation@1.0 (dispute_type={trigger, step, rollback}, rationale_url, severity)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per run_id
- **Idempotency-Key:** sha256(run_id, dispute_id)
- **Ack/Nack:** case_id in <=30s else retry/backoff

- **Side-Effects:** freeze further steps on high severity; open legal/compliance workflow
- **HITL Token:** required when severity >= high
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=DRContestation@1.0 | json_schema_uri=uri://schema/dr-contestation-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: IRDRIncidentLink (IR Integration) [Informative, optional]

- **Producer(s):** H2
- **Topic/Path:** resilience.dr.ir_link
- **Schema/Format:** IRDRIncidentLink@1.0 (incident_id, run_id, links[{type, uri}])
- **Classification:** C2
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(incident_id, run_id)
- **Ack/Nack:** SIEM/IR system returns CaseID in <=30s; retry/backoff
- **Side-Effects:** attach DRRunReport and key DRActionOutcome events to IR case
- **Observability:** trace_id, mission_id, incident_id, run_id
- **Retention/TTL:** per IR policy (>=1 year)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRDRIncidentLink@1.0 | json_schema_uri=uri://schema/irdr-incident-link-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: RollbackTrace (Rollback Lineage Event) [Informative, optional]

- **Producer(s):** H2
- **Topic/Path:** resilience.dr.rollback_trace
- **Schema/Format:** RollbackTrace@1.0 (run_id, steps[], reason, time_to_recover)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per run_id
- **Idempotency-Key:** sha256(run_id, rollback_digest)
- **Ack/Nack:** broker ACK or REST 201; retry/backoff
- **Side-Effects:** mark DRRunReport status “rolled_back”; notify owners
- **Observability:** trace_id, mission_id, plan_id, run_id
- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When any rollback step is executed in a run

schema_id=RollbackTrace@1.0 | json_schema_uri=uri://schema/rollback-trace-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; H2 (aggregation)
- **Topic/Path:** resilience.dr.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (labels={helpful|neutral|harmful})
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, run_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, run_id, labels

- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, evaluating_trigger, prechecks, executing_failover, monitoring, success, rollback_initiated, rolling_back, contestation_workflow, failed, closed }

transition(idle -> evaluating_trigger) when SEV-1 incident or scheduled DR test arrives

transition(evaluating_trigger -> prechecks) when trigger eligible and approvals present

transition(prechecks -> executing_failover) when all prechecks pass

transition(executing_failover -> monitoring) when steps complete

transition(monitors -> success) when health converges and SLOs met

transition(monitors -> rollback_initiated) when health fails to converge or explicit rollback command received

transition(rollback_initiated -> rolling_back) start rollback steps

transition(rolling_back -> closed) when restored to pre-state

transition(any -> contestation_workflow) when DRContestation opens or stakeholder_disagreement_score >= 0.5

transition(* -> failed) on validation error or timeout

timeout(executing_failover, plan_timeout) -> rollback_initiated

idempotency_key = sha256(run_id, step_id, status)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 DRActionOutcome	Required	Always	Step-level observability & audit trail
OC-2 DRRunReport	Conditionally Required	Tests executed or signed summaries required	Compliance & governance reporting

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-3 DRContestation	Optional	Contestability enabled	Governance/appeals workflow
OC-4 IRDRIncidentLink	Optional	IR/SIEM integration present	Incident case traceability
OC-5 RollbackTrace	Conditionally Required	Any rollback executed	Assured reconstitution traceability
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: CP-2, CP-7, CP-9, CP-10; IR-4 as applicable
- **HITL required:** initiating production failover; DNS cutover; declaring “success” with unmet SLOs; operating outside allowed region constraints
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5
- **Manual outside agent:** customer comms; executive business-impact decisions

SLOs and KPIs [Informative]

- FailoverStartAck_p95 <= 120 s (from trigger to first step outcome)
- RTO_AttainmentRate_Quarter >= 95 percent
- RollbackMTTR_p95 <= 20 min
- FalseTriggerRate_30d <= 1 percent
- EvidenceCompletenessRate >= 99 percent (runs with all steps logged)

Outputs index [Informative]

[OC-1 DRActionOutcome], [OC-2 DRRunReport], [OC-3 DRContestation], [OC-4 IRDRIncidentLink], [OC-5 RollbackTrace], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (H2) [Informative]

Model and training profile [Informative]

model_id=dr-orchestration-text-model; temperature=0.1; max_tokens_out=900
prompt_pack_id=dr-orch-v1 (plan-parsing, safety gates, rollback-first)
RAG: sources={DR plan repo, past DR reports, incident postmortems, service/region inventory}; max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; eval on plan parsing accuracy and hallucination bounds
guardrails: deny production-changing tools; only emit DRActionOutcome/DRRunReport; orchestrator calls are out-of-band

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (plans, triggers, step outcomes), ttl=365d
semantic_memory: namespaces=["dr-plans","dr-reports","incidents"]; embeddings=text-embedding-sec-v1; k=10
durable_state_store: event-sourced run ledger; snapshot at run completion
consistency: at-least-once (events); exactly-once per (run_id, step_id) at consumer via idempotency_key
idempotency: per Output Contracts

Decision and routing logic [Informative]

failover_trigger_score = $0.4 \text{severity_weight} + 0.3 \text{slo_breach_weight} + 0.2 \text{region_impact_weight} + 0.1 \text{confidence}$
initiate_failover = (failover_trigger_score >= theta_trigger) and approvals_present = true
rollback_score = $0.5 \text{health_nonconvergence} + 0.3 \text{error_rate_spike} + 0.2 * \text{step_failure_density}$
initiate_rollback = (rollback_score >= theta_rollback) or explicit_rollback_command = true

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial, jailbreak]
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly D3FEND/ATT&CK-flavored prompts (e.g., unsafe plan

mutations)

rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; plan_id/version; trigger evidence; step results; rollback lineage; hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRDRIncidentLink (OC-4) to attach DRRRunReport and key outcomes to IR case

Change Impact Assessment [Informative]

n/a (covered by DR plan governance); capture deviations in DRRRunReport

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6); governance-reviewed updates may refine prompt_pack or plan templates (no auto-training on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress

legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: DR Test Plans (Git/REST); Outage Alerts (Monitoring/Incident/OTel/PD REST)

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as used)

Safety and abuse prevention [Informative]

kill_switch on provenance/signature mismatch; safe hold on repeated NACKs; forbid production actions without HITL

blast_radius caps: single production failover per service per 6 hours without executive waiver

cost/QPS limits per mission_id; alerts on breach

Testing and validation [Informative]

contract tests for DRActionOutcome/DRRunReport; offline replay of historic plans; red-team plan mutation attempts; drift checks and rollback

Deployment and lifecycle [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

HPA by queue depth; canary via test_mode runs; auto-rollback on validation failures; SBOM + attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-34; NIST SP 800-53 Rev. 5 (CP-2/CP-7/CP-9/CP-10); NIST CSF 2.0; ISO 22301:2019; MITRE D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (H2) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** DR Test Plans (Git/REST); Outage Alerts (Monitoring/Incident Webhooks / OTel / PD REST)
- **Native Protocol(s) Produced:** DRActionOutcome (Kafka/AMQP/REST); DRRunReport (Git/REST)
- **MCP Context Fields:**
 - **Required:** mission_id; role="DROrchestrationAgent"; intent="recover"; constraints=["region:primary"]; decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; legal_hold; rollback_procedures_ref
- **Enforcement Note:** Orchestrator/PEP components must verify provenance.attestation and enforce constraints; production cutovers require HITL/CAB/IR gates.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native + MCP-wrapped examples as above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

H3. Resilience Engineering Agent

Agent Blueprint [Informative]

Purpose: Execute chaos/resilience experiments and verify self-healing behaviors against defined success criteria; produce attested ResilienceTestReport artifacts.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Chaos Experiment Library (Git/REST):** reusable patterns such as pod-kill, latency injection, dependency blackhole, disk-full, node-drain; owners, evidence store paths, steady-state probes.
- **Resilience Policy and Guardrails (Governance Repo/REST):** max blast radius, allowed environments/windows, HITL rules, allowed fault types, evidence retention.
- **Environment and Sandbox Flags (Feature-flag/Orchestrator REST):** toggles for sandbox=true, canary scope, traffic shaping, TTLs.
- **SLO and Health Signals (SLO Catalog/REST, OpenTelemetry):** success criteria, error budget, metric selectors and windows.

Model training / knowledge (what the LLM relies on):

- Prompt pack for experiment design and safety rubric (blast radius math, steady-state hypotheses, rollback-first).
- RAG over experiment templates, past run reports, policy and guardrail docs, SLO catalog; do not train on customer data, dereference via evidence_refs.
- Guardrails: deny production scope unless constraints and HITL are satisfied; enforce change_window and timebox; write access limited to report/event sinks and optional Git PRs.

Decisions it makes (deterministic + model-assisted):

- **Eligibility and scoping:** choose experiment, environment, and canary percent under guardrails; compute experiment_risk_score and require HITL when thresholds are exceeded.
- **Execution planning:** order faults, insert health checks and safety waits; enforce timebox and blast radius.
- **Pass/fail judgment:** evaluate SLO deltas and steady-state probes; classify result and recommend remediation.

- **Rollback and revert:** revert faults immediately on probe failure, timeouts, or HITL stop; ensure evidence-linked traceability.
- **Remediation proposal:** open PRs against playbooks/policies when repeatable gaps are detected.

Routing / where outputs go:

- **ResilienceTestReport** → Kafka/AMQP/REST to governance dashboards and data lake.
- **Optional PRs** → Git repos for playbooks/policies with diffs and links to evidence.
- **Tickets/alerts** → ITSM/IR when critical gaps or guardrail violations occur.

Automation scope vs. manual/HITL:

- Fully automated: eligibility checks, experiment orchestration in sandbox/canary, step telemetry capture, report emission.
- **HITL required:** any production scope; blast_radius_percent over policy threshold; disabling automatic revert; tests during active incidents.
- Manual outside agent: business approval to run in production windows; executive comms and risk acceptance.

Security Domain: Resilience, Continuity, and Recovery

Inputs (native protocols consumed) [Informative]

1. **Chaos Experiment Library (Git/REST)** — reusable experiment patterns and probes.
2. **Resilience Policy and Guardrails (Governance Repo/REST)** — allowed scope, windows, HITL rules.
3. **Environment and Sandbox Flags (Feature-flag/Orchestrator REST)** — sandbox, canary, traffic shaping.
4. **SLO and Health Signals (SLO Catalog/REST, OpenTelemetry)** — pass/fail metrics and selectors.

Example: Consumed Protocol — Chaos Experiment Library (Git/REST)

[Informative]

Native payload (Litmus/ChaosMesh-style YAML)

experiment_id: pod-kill-payments

```
version: "1.2.0"
target:
  kind: Deployment
  namespace: payments
  selector: "app=payments-api"
method:
  fault: pod-kill
  mode: random-max-percentage
  value: "10%" # kill up to 10% of pods
duration_seconds: 300
steady_state_hypothesis:
  probes:
    - name: "p95-latency"
      otel_metric: "http.server.duration.p95"
      threshold_ms: 300
evidence_store: "s3://resilience-evidence/payments/"
owners: ["payments.sre"]
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h3-chaos-1111-2222-3333-4444",
    "thread_id": "uuid-exp-pod-kill-payments",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "ResilienceEngineeringAgent",
    "intent": "evaluate",
    "policy_refs": ["CP-7", "SC-5"],
```

```

    "constraints": ["sandbox:true", "blast_radius<=5%", "timebox_minutes:30",
"change_window:offhours"],
    "decision_basis": {
        "evidence_refs": ["uri://git/resilience/experiments/pod-kill-payments@v1.2.0"],
        "confidence": 0.96,
        "explanation_ref": "uri://kb/resilience/experiment-design#pod-kill"
    },
    "provenance": {
        "producer_spiffe": "spiffe://enterprise/resilience/resilience-engineering-agent",
        "signing_kid": "kid-chaos-h3-01",
        "attestation_ref": "uri://slsa/attestations/resilience-engineering@sha256:chaos01"
    },
    "classification": "C1",
    "legal_hold": false
},
    "native_payload": "experiment_id: pod-kill-payments\nversion: \"1.2.0\" ... (elided) ..."
}

```

Example: Consumed Protocol — Resilience Policy and Guardrails (Governance Repo/REST) [Informative]

Native payload (JSON policy)

```

{
    "policy_id": "RES-GUARD-01",
    "allowed_environments": ["staging", "prod-canary"],
    "max_blast_radius_percent": 5,
    "allowed_faults": ["pod-kill", "network-latency", "cpu-hog"],
    "hitl_required_when": ["environment == 'production'", "blast_radius_percent > 2"],
    "change_window": "offhours",
    "evidence_retention_days": 365
}

```

```
}
```

MCP-wrapped payload

```
{
```

```
  "mcp_context": {
```

```
    "mcp_version": "0.9",
```

```
    "mission_id": "uuid-h3-guard-5555-6666-7777-8888",
```

```
    "thread_id": "uuid-policy-RES-GUARD-01",
```

```
    "task_id": "uuid-9911-8822-7733-6644",
```

```
    "role": "ResilienceEngineeringAgent",
```

```
    "intent": "evaluate",
```

```
    "policy_refs": ["CP-2", "CP-7", "CP-10"],
```

```
    "constraints": ["sandbox:true", "blast_radius<=5%", "change_window:offhours",  
"no_prod_without_HITL"],
```

```
    "decision_basis": {
```

```
      "evidence_refs": ["uri://git/resilience/policies/RES-GUARD-01.json"],
```

```
      "confidence": 0.97,
```

```
      "explanation_ref": "uri://kb/resilience/guardrails-and-risk"
```

```
    },
```

```
    "provenance": {
```

```
      "producer_spiffe": "spiffe://enterprise/resilience/resilience-engineering-agent",
```

```
      "signing_kid": "kid-guard-h3-02",
```

```
      "attestation_ref": "uri://slsa/attestations/resilience-engineering@sha256:guard02"
```

```
    },
```

```
    "classification": "C2",
```

```
    "legal_hold": false
```

```
  },
```

```
  "native_payload": { "...": "..." }
```

```
}
```

Example: Consumed Protocol — Environment and Sandbox Flags (Feature-flag/Orchestrator REST) [Informative]

Native payload (feature flag gate)

```
{  
  "flag_key": "resilience.sandbox",  
  "service": "payments-api",  
  "environment": "staging",  
  "enabled": true,  
  "canary_percent": 10,  
  "traffic_shaping": {"route": "canary", "weight_percent": 10},  
  "ttl_minutes": 45,  
  "last_updated": "2025-08-15T14:05:00Z"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-h3-flags-3333-4444-5555-6666",  
    "thread_id": "uuid-flag-resilience.sandbox-payments",  
    "task_id": "uuid-4411-5522-6633-7744",  
    "role": "ResilienceEngineeringAgent",  
    "intent": "evaluate",  
    "policy_refs": ["CP-7", "SC-5"],  
    "constraints": ["sandbox:true", "timebox_minutes:45", "blast_radius<=10%"],  
    "decision_basis": {  
      "evidence_refs": ["uri://flags/payments-api/resilience.sandbox@2025-08-15T14:05:00Z"],  

```

```

    "confidence": 0.95,
    "explanation_ref": "uri://kb/resilience/canary-and-traffic-shaping"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/resilience/resilience-engineering-agent",
    "signing_kid": "kid-flags-h3-03",
    "attestation_ref": "uri://slsa/attestations/resilience-engineering@sha256:flags03"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — SLO and Health Signals (SLO Catalog/REST, OpenTelemetry) [Informative]

Native payload

```

{
  "slo_id": "payments-api-latency-p95",
  "objective_ms": 300,
  "window": "7d",
  "error_budget_fraction": 0.05,
  "otel_query": {
    "metric": "http.server.duration.p95",
    "labels": {"service.name": "payments-api", "http.route": "/charge"}
  }
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h3-slo-7777-8888-9999-0000",
    "thread_id": "uuid-slo-payments-api-latency-p95",
    "task_id": "uuid-abcd-ef01-2345-6789",
    "role": "ResilienceEngineeringAgent",
    "intent": "evaluate",
    "policy_refs": ["CP-10", "PM-5"],
    "constraints": ["sandbox:true"],
    "decision_basis": {
      "evidence_refs": [
        "uri://slo/catalog/payments-api-latency-p95",
        "uri://otel/metrics/http.server.duration.p95?service.name=payments-
api&route=/charge"
      ],
      "confidence": 0.94,
      "explanation_ref": "uri://kb/resilience/slo-pass-fail-criteria"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/resilience/resilience-engineering-agent",
      "signing_kid": "kid-slo-h3-04",
      "attestation_ref": "uri://slsa/attestations/resilience-engineering@sha256:slo04"
    },
    "classification": "C1",
    "legal_hold": false
  },
}

```

```
"native_payload": { "...": "..." }  
}
```

Outputs (native) [Informative]

- **ResilienceTestReport** via Kafka/AMQP/REST with evidence URIs, metrics deltas, remediation recommendations.
- **Optional Git PR** to update playbooks or policies when gaps are found.

MCP context (required) [Informative]

mission_id; role="ResilienceEngineeringAgent"; intent="evaluate"; policy_refs (e.g., CP-2, CP-7, CP-10; SC-5; SA-10); decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

constraints (e.g., "sandbox:true", "blast_radius<=5%", "timebox_minutes:30", "change_window:offhours", "no_prod_without_HITL"); classification (C1–C2, elevate to C3 if customer data involved); legal_hold (true when tests run during active incidents)

Enforcement note [Informative]

PEPs must verify provenance.attestation and enforce constraints; production experiments require HITL and policy-compliant windows; automatic revert must always be available.

NIST SP 800-160v2 linkage [Informative]

Develop/Maintain/Recover — proactive robustness and graceful degradation via fault injection and self-healing validation with assured evidence.

Automation feasibility [Informative]

High (experiment execution, guardrail enforcement, reporting). High-risk scopes may require HITL.

Output Contracts (merged) [Informative]

OC-1: ResilienceTestReport (Attested Report) [Informative]

- **Producer(s):** H3
- **Topic/Path:** resilience.tests.report (Kafka/AMQP) or POST /resilience/reports (REST)

- **Schema/Format:** ResilienceTestReport@1.0 (mission_id, experiment_id, run_id, env, canary_percent, constraints, start_ts, end_ts, slo_deltas, probe_results[], remediation_recommendations[], evidence_refs, provenance)
- **Classification:** C1 by default; C2 if includes sensitive dependency topology
- **Delivery:** at-least-once
- **Ordering:** per run_id
- **Idempotency-Key:** sha256(run_id, report_digest)
- **Ack/Nack:** broker ACK<=5s or REST 201; NACK=4xx/5xx
- **Timeouts/Retry:** exp-backoff<=5x; on failure open ticket and persist local snapshot
- **Side-Effects:** update governance dashboards; store JSONL copy in evidence store
- **HITL Token:** required only if test ran in production scope
- **Observability:** trace_id, mission_id, experiment_id, run_id, classification_label, provenance.attestation
- **Retention/TTL:** 2 years (tests), 7 years if legal_hold=true

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ResilienceTestReport@1.0 | json_schema_uri=uri://schema/resilience-test-report-1.0.json | sha256= | producers=H3 | consumers=GovDash-01, Audit-01, DataLake-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: ExperimentStepOutcome (Stepwise Event) [Informative]

- **Producer(s):** H3
- **Topic/Path:** resilience.tests.step_outcome (Kafka/AMQP)
- **Schema/Format:** ExperimentStepOutcome@1.0 (run_id, step_id, step_type, status, started_at, ended_at, evidence_refs, notes)
- **Classification:** C1

- **Delivery:** at-least-once
- **Ordering:** per run_id then step_id
- **Idempotency-Key:** sha256(run_id, step_id, status)
- **Ack/Nack:** broker ACK<=5s; retry/backoff
- **Side-Effects:** append to audit journal; correlate into ResilienceTestReport
- **HITL Token:** none
- **Observability:** trace_id, mission_id, run_id, step_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When step-level observability is enabled for this deployment

schema_id=ExperimentStepOutcome@1.0 | json_schema_uri=uri://schema/experiment-step-outcome-1.0.json

Conformance: Normative when condition is met.

OC-3: PolicyChangeProposal (Playbook/Policy PR) [Informative, optional]

- **Producer(s):** H3
- **Topic/Path:** repo=ops/playbooks// (PR) or governance://policies/resilience
- **Schema/Format:** PolicyChangeProposal@1.0 (reason, recommended_change, risk_rank, linked_evidence)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per service
- **Idempotency-Key:** sha256(service, change_hash)
- **Ack/Nack:** PR number or REST 201; retry/backoff
- **Side-Effects:** request reviews from owners; gate merge on HITL where required
- **HITL Token:** required when affects production runbooks
- **Observability:** trace_id, mission_id, review_state
- **Retention/TTL:** per repo policy

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When the deployment enables automatic proposal of playbook/policy changes

schema_id=PolicyChangeProposal@1.0 | json_schema_uri=uri://schema/policy-change-proposal-1.0.json

Conformance: Normative when condition is met.

OC-4: IRResilienceViolationEvent (IR Integration) [Informative, optional]

- **Producer(s):** H3
- **Topic/Path:** resilience.tests.ir_violation
- **Schema/Format:** IRResilienceViolationEvent@1.0 (severity, violated_probe, slo_delta, impacted_routes, recommendations_ref)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(run_id, violated_probe)
- **Ack/Nack:** SIEM/IR system CaseID in <=30s; retry/backoff
- **Side-Effects:** open IR case, attach ResilienceTestReport and key step outcomes
- **Observability:** trace_id, mission_id, incident_id
- **Retention/TTL:** per IR policy

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRResilienceViolationEvent@1.0 | json_schema_uri=uri://schema/ir-resilience-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: ResilienceContestation (Explainability and Appeals) [Informative, optional]

- **Producer(s):** H3, Legal-Portal-01, Compliance-Portal-01
- **Topic/Path:** resilience.tests.contestation

- **Schema/Format:** ResilienceContestation@1.0 (dispute_type={scope, guardrail, result}, rationale_url, severity)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per run_id
- **Idempotency-Key:** sha256(run_id, dispute_id)
- **Ack/Nack:** case_id in <=30s else retry/backoff
- **Side-Effects:** freeze further experiments in scope; open legal/compliance workflow
- **HITL Token:** required when severity >= high
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=ResilienceContestation@1.0 | json_schema_uri=uri://schema/resilience-contestation-1.0.json

Conformance: Normative if implemented or claimed.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; H3 (aggregation)
- **Topic/Path:** resilience.tests.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (labels={helpful|neutral|harmful})
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, run_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, run_id, labels

- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, planning, guardrail_check, provisioning_sandbox, executing, monitoring, revert_faults, success, contestation_workflow, failed, closed }

transition(idle -> planning) when eligible experiment request arrives

transition(planning -> guardrail_check) when experiment and environment selected

transition(guardrail_check -> provisioning_sandbox) when constraints satisfied and approvals present

transition(provisioning_sandbox -> executing) when flags/traffic shaping active

transition(executing -> monitoring) when faults injected

transition(monitors -> success) when probes pass and SLO deltas within thresholds

transition(monitors -> revert_faults) when probes fail or timebox expires

transition(revert_faults -> closed) when environment restored

transition(any -> contestation_workflow) when ResilienceContestation opens or stakeholder_disagreement_score >= 0.5

transition(* -> failed) on validation error or policy violation

timeout(executing, timebox_minutes) -> revert_faults

idempotency_key = sha256(run_id, step_id, status)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ResilienceTestReport	Required	Always	Evidence-based resilience assurance
OC-2 ExperimentStepOutcome	Conditionally Required	Step-level observability enabled	Fine-grained auditability

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-3 PolicyChangeProposal	Conditionally Required	Automatic proposal workflow enabled	Continuous improvement of runbooks
OC-4 IRResilienceViolationEvent	Optional	IR/SIEM integration present	Incident response integration
OC-5 ResilienceContestation	Optional	Contestability enabled	Governance and appeals workflow
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Learning loop

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: CP-2, CP-7, CP-10; SC-5; SA-10 (plus local governance policies)
- **HITL required:** any production environment; blast_radius_percent > policy max; disabling auto-revert; change_window exceptions
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5
- **Manual outside agent:** production risk acceptance; customer comms

SLOs and KPIs [Informative]

- ExperimentSuccessRate_30d >= 90 percent (in allowed scope)
- BlastRadiusViolationRate_30d <= 0.5 percent
- TimeToRevertFault_p95 <= 5 min
- EvidenceCompletenessRate >= 99 percent
- MeanSLODelta_p95 <= objective_threshold per experiment class

Outputs index [Informative]

[OC-1 ResilienceTestReport], [OC-2 ExperimentStepOutcome], [OC-3 PolicyChangeProposal], [OC-4 IRResilienceViolationEvent], [OC-5 ResilienceContestation], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (H3) [Informative]

Model and training profile [Informative]

model_id=resilience-engineering-text-model; temperature=0.1; max_tokens_out=900
prompt_pack_id=resilience-tests-v1 (safety rubric, steady-state patterns, rollback-first)
RAG: sources={experiment library, guardrail policies, SLO catalog, past reports};
max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; evaluate on plan parsing accuracy and safety-rule adherence
guardrails: deny production unless constraints and HITL satisfied; enforce blast radius, timebox, change_window

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (plans, steps, probes, approvals), ttl=365d
semantic_memory: namespaces=["experiments","policies","slo","reports"];
embeddings=text-embedding-sec-v1; k=10
durable_state_store: event-sourced run ledger; snapshot after report emission
consistency: at-least-once for events; exactly-once per (run_id, step_id) at consumers via idempotency_key
idempotency: per Output Contracts

Decision and routing logic [Informative]

experiment_risk_score = $0.4 \text{blast_radius_norm} + 0.3 \text{env_risk} + 0.2 \text{recent_incident_weight} + 0.1 \text{confidence_penalty}$
pass_if = (all_probes == pass) and (slo_deltas within thresholds)
open_policy_change_pr_if = repeat_failures_rolling_30d >= n_threshold or
critical_gap_detected = true

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial, jailbreak]
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly ATT&CK/D3FEND-flavored probes (prompt-injection, unsafe fault proposals)

rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who, what, why; constraints applied; probes and SLO deltas; revert rationale; hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRResilienceViolationEvent (OC-4) for critical probe failures; attach report and steps

Change Impact Assessment [Informative]

summarize recurring failure motifs and link to PolicyChangeProposal (OC-3)

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6); governance reviews feed prompt_pack refinements (no auto-training on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress

legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: Chaos Experiment Library; Resilience Policy and Guardrails; Environment and Sandbox Flags; SLO and Health Signals

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as used)

Safety and abuse prevention [Informative]

kill_switch on provenance/signature mismatch or guardrail breach; auto-revert on probe failure; cap concurrent experiments per service

Testing and validation [Informative]

contract tests for OC schemas; offline replay of past experiments; red-team safety-rule evasion attempts; drift checks and rollback

Deployment and lifecycle [Informative]

scale on queue depth; canary in staging; auto-rollback on validation failures; SBOM and attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-34; NIST SP 800-53 Rev. 5 (CP, SA, SC families); NIST CSF 2.0; ISO 22301:2019; MITRE D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (H3) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Chaos Experiment Library (Git/REST); Resilience Policy and Guardrails (Governance Repo/REST); Environment and Sandbox Flags (Feature-flag/Orchestrator REST); SLO and Health Signals (SLO Catalog/REST, OpenTelemetry)
- **Native Protocol(s) Produced:** ResilienceTestReport (Kafka/AMQP/REST); ExperimentStepOutcome (Kafka/AMQP); PolicyChangeProposal (Git/REST, conditional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="ResilienceEngineeringAgent"; intent="evaluate"; policy_refs; decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** constraints; classification; legal_hold
- **Enforcement Note:** PEPs must verify provenance.attestation and enforce constraints including sandbox, blast_radius, timebox, and change_window; production scope requires HITL.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native and MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

H4. Failover Automation Agent

Agent Blueprint [Informative]

Purpose: Automatically execute failover for designated critical workloads when health checks and telemetry breach thresholds; suppress flap, honor guardrails, and emit auditable **FailoverEvent**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Health Check Streams (LB/DNS/Service Registry):** ALB/ELB target group health, Route53/Consul/Envoy checks, DNS HC status, consecutive failure counts, failure reasons, evaluated_at.
- **Telemetry/SLO Signals (OpenTelemetry/Monitoring REST):** availability, error rate, latency, saturation metrics; windowed thresholds; breach indicators; evidence URIs.

Model training / knowledge (what the LLM relies on):

- Prompt pack: failover safety rubric (multi-signal quorum, cooldown/flap-suppression math, canary-first, rollback-first).
- RAG sources: service registry/inventory, historical incident timelines, past failover outcomes, regional capacity maps, DR plans; dereference sensitive items via evidence_refs (no customer data in training).
- Guardrails: **no direct production mutations** from this card; cloud/orchestrator calls are executed by PEP/orchestrator services out-of-band; this agent decides/authorizes and produces signed events.

Decisions it makes (deterministic + model-assisted):

- **Trigger eligibility:** compute failover_trigger_score from multi-signal evidence; require quorum across at least N independent sources; verify cooldown not violated.
- **Scope selection:** choose **canary_failover** vs. **full service** based on blast radius policy, capacity, and SLO breach intensity.
- **Action plan synthesis:** DNS flip, traffic shift %, autoscaling targets, warmup times; include rollback plan and success criteria.

- **Rollback/initiate revert:** if health does not converge within `convergence_window` or negative SLO deltas worsen beyond `theta_worsen`.
- **Flap suppression:** dampen repeated toggles with exponential cooldown; require additional evidence on repeated oscillations.

Routing / where outputs go:

- **FailoverEvent** → Kafka/AMQP (or REST) for orchestrators/PEPs, governance dashboards, and audit.
- **RollbackTrace** (when executed) → same event bus for lineage.
- **IR/ITSM linking** → optional event to attach run details to an active incident/case.

Automation scope vs. manual/HITL:

- Fully automated: detection, scoring, canary failover, event emission, cooldown/flap suppression.
- **HITL required:** cross-region/global DNS cutover; failover that exceeds `max_blast_radius` policy; override of cooldown; declaring “success” when SLOs unmet.
- Manual outside agent: executive/customer comms; business approval for extended degraded-service periods.

Security Domain: Resilience, Continuity, and Recovery

Inputs (native protocols consumed) [Informative]

1. **Health Check Streams (LB/DNS/Service Registry)** — target group/DNS/sidecar health and failure reasons.
2. **Telemetry/SLO Signals (OpenTelemetry/Monitoring REST)** — availability/error/latency/saturation against thresholds.

Example: Consumed Protocol — Health Check Streams [Informative]

Native payload

```
{
  "check_id": "hc-payments-alb",
  "system": "alb",
  "resource": "tg/payments-api",
```

```

"region": "us-east-1",
"status": "unhealthy",
"unhealthy_targets": 9,
"total_targets": 10,
"consecutive_failures": 5,
"failure_reasons": ["http_5xx", "timeout"],
"evaluated_at": "2025-08-15T14:25:12Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h4-fail-1111-2222-3333-4444",
    "thread_id": "uuid-hc-hc-payments-alb",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "FailoverAutomationAgent",
    "intent": "recover",
    "policy_refs": ["CP-10", "CP-7"],
    "constraints": ["min_evidence_sources:2", "cooldown_seconds:600", "region:primary",
"canary_failover:true"],
    "decision_basis": {
      "evidence_refs": ["uri://lb/health/tg/payments-api@2025-08-15T14:25:12Z"],
      "confidence": 0.92,
      "explanation_ref": "uri://kb/dr/failover-signals#lb-health"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/resilience/failover-automation-agent",

```

```

    "signing_kid": "kid-hc-h4-01",
    "attestation_ref": "uri://slsa/attestations/failover-automation@sha256:hc01"
  },
  "classification": "C2",
  "legal_hold": false,
  "mission_link_refs": []
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — Telemetry/SLO Signals [Informative]

Native payload

```

{
  "service": "payments-api",
  "region": "us-east-1",
  "window": "5m",
  "metrics": {
    "availability_percent": 98.4,
    "error_rate_per_min": 620,
    "latency_p95_ms": 840
  },
  "thresholds": {
    "availability_percent_min": 99.5,
    "error_rate_per_min_max": 200,
    "latency_p95_ms_max": 400
  },
  "breaches": ["availability", "error_rate", "latency"],
  "observed_at": "2025-08-15T14:25:10Z",

```

```

"evidence_refs": [
  "uri://otel/metrics/payments-api/availability@2025-08-15T14:25:10Z",
  "uri://otel/metrics/payments-api/error_rate@2025-08-15T14:25:10Z"
]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h4-fail-1111-2222-3333-4444",
    "thread_id": "uuid-slo-payments-api-5m",
    "task_id": "uuid-55aa-66bb-77cc-88dd",
    "role": "FailoverAutomationAgent",
    "intent": "recover",
    "policy_refs": ["CP-10", "PM-5"],
    "constraints": ["min_evidence_sources:2", "cooldown_seconds:600",
"max_blast_radius:service"],
    "decision_basis": {
      "evidence_refs": [
        "uri://otel/metrics/payments-api/availability@2025-08-15T14:25:10Z",
        "uri://otel/metrics/payments-api/error_rate@2025-08-15T14:25:10Z"
      ],
      "confidence": 0.94,
      "explanation_ref": "uri://kb/dr/failover-signals#slo-breach"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/resilience/failover-automation-agent",

```

```

    "signing_kid": "kid-otel-h4-02",
    "attestation_ref": "uri://slsa/attestations/failover-automation@sha256:otel02"
  },
  "classification": "C2",
  "legal_hold": true,
  "mission_link_refs": ["uri://incident/INC-DR-2025-0815-0041"]
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **FailoverEvent** (Kafka/AMQP/REST) — action plan, decision rationale, timing, success/failure, evidence and rollback hooks.
- **RollbackTrace** (conditionally, when rollback executes) — lineage of revert actions and convergence results.
- (*Out-of-band*) orchestrator/cloud API calls (DNS flip, ASG scale, traffic shift) are referenced in evidence but executed by PEP/orchestrators.

MCP context (required) [Informative]

mission_id; role="FailoverAutomationAgent"; intent="recover"; decision_basis (evidence_refs from >= N distinct sources, confidence, explanation_ref); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

constraints (e.g., "min_evidence_sources:2", "cooldown_seconds:600", "max_blast_radius:service", "region:primary", "canary_failover:true"); policy_refs (CP-10, CP-2, CP-7, SC-5); classification; legal_hold; mission_link_refs (e.g., active incident URIs)

Enforcement note [Informative]

PEPs/orchestrators MUST verify provenance.attestation and constraints; production/global cutovers require HITL and CAB/IR gates; consumers enforce exactly-once per action_id using idempotency keys.

NIST SP 800-160v2 linkage [Informative]

Maintain & Recover — assured graceful degradation and reconstitution with verifiable artifacts.

Automation feasibility [Informative]

High (fully automatable with policy/HITL gates for risky or cross-region actions).

Output Contracts (merged) [Informative]

OC-1: FailoverEvent (Decision + Action Plan) [Informative]

- **Producer(s):** H4
- **Topic/Path:** resilience.failover.event (Kafka/AMQP) or POST /failover/events (REST)
- **Schema/Format:** FailoverEvent@1.0 (mission_id, service, region, scope={canary|service|region}, action_plan[], start_ts, decision_rationale, constraints[], evidence_refs[], success_criteria, cooldown_applied, orchestrator_refs[], rollback_plan_ref, classification_label, provenance)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per action_id
- **Idempotency-Key:** sha256(action_id, plan_digest)
- **Ack/Nack:** broker ACK<=5s or REST 202; NACK=4xx/5xx
- **Timeouts/Retry:** exp-backoff<=5x; on repeated NACK, hold actions and escalate HITL
- **Side-Effects:** append to tamper-evident journal; notify incident thread if mission_link_refs present
- **HITL Token:** required when scope=region or max_blast_radius would be exceeded
- **Observability:** trace_id, mission_id, action_id, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (production), 1 year (tests)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=FailoverEvent@1.0 | json_schema_uri=uri://schema/failover-event-1.0.json | sha256= | producers=H4 | consumers=PEP-Orch-01, GovDash-01, IR-Case-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: RollbackTrace (Reversion Lineage) [Informative]

- **Producer(s):** H4
- **Topic/Path:** resilience.failover.rollback_trace
- **Schema/Format:** RollbackTrace@1.0 (mission_id, action_id, reason, steps[], time_to_recover, convergence_metrics, evidence_refs)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per action_id
- **Idempotency-Key:** sha256(action_id, rollback_digest)
- **Ack/Nack:** broker ACK or REST 201; retry/backoff
- **Side-Effects:** mark associated FailoverEvent as rolled_back in audit ledger
- **HITL Token:** none (reporting)
- **Observability:** trace_id, mission_id, action_id
- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When any rollback step is executed

schema_id=RollbackTrace@1.0 | json_schema_uri=uri://schema/rollback-trace-1.0.json | sha256= | producers=H4 | consumers=GovDash-01, IR-Case-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: IRFailoverIncidentLink (IR Integration) [Informative, optional]

- **Producer(s):** H4
- **Topic/Path:** resilience.failover.ir_link

- **Schema/Format:** IRFailoverIncidentLink@1.0 (incident_id, action_id, links[{type,uri}], severity, legal_hold)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(incident_id, action_id)
- **Ack/Nack:** IR system CaseID in <=30s; retry/backoff
- **Side-Effects:** attach FailoverEvent/RollbackTrace to IR case
- **Observability:** trace_id, mission_id, incident_id
- **Retention/TTL:** per IR policy

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRFailoverIncidentLink@1.0 | json_schema_uri=uri://schema/ir-failover-incident-link-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: CanaryPromotionDecision (Canary → Service) [Informative, optional]

- **Producer(s):** H4
- **Topic/Path:** resilience.failover.canary_promotion
- **Schema/Format:** CanaryPromotionDecision@1.0 (action_id, canary_percent, health_convergence, promotion_thresholds, decision, evidence_refs)
- **Classification:** C1–C2
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(action_id, decision, canary_percent)
- **Ack/Nack:** broker ACK or REST 201; retry/backoff
- **Side-Effects:** instruct orchestrators to widen traffic if decision=promote
- **HITL Token:** required when promotion exceeds policy max_blast_radius
- **Observability:** trace_id, mission_id, action_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When deployment enables canary_failover workflow

schema_id=CanaryPromotionDecision@1.0 | json_schema_uri=uri://schema/canary-promotion-decision-1.0.json

Conformance: Normative when condition is met.

OC-5: FailoverContestation (Explainability & Appeals) [Informative, optional]

- **Producer(s):** H4, Legal/Compliance portals
- **Topic/Path:** resilience.failover.contestation
- **Schema/Format:** FailoverContestation@1.0 (dispute_type={trigger, scope, rollback}, rationale_url, severity)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per action_id
- **Idempotency-Key:** sha256(action_id, dispute_id)
- **Ack/Nack:** case_id in <=30s; retry/backoff
- **Side-Effects:** freeze further promotions; open legal/compliance workflow
- **HITL Token:** required when severity >= high
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=FailoverContestation@1.0 | json_schema_uri=uri://schema/failover-contestation-1.0.json

Conformance: Normative if implemented or claimed.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; H4 (aggregation)
- **Topic/Path:** resilience.failover.feedback

- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, action_id, labels={helpful|neutral|harmful}, notes)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(review_id, action_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, action_id, labels
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, gathering_evidence, trigger_eligible, canary_failover, monitoring, promote_or_hold,

success, rollback_initiated, rolling_back, contestation_workflow, failed, closed }

transition(idle -> gathering_evidence) when any breach arrives

transition(gathering_evidence -> trigger_eligible) when quorum >= min_evidence_sources and cooldown_satisfied

transition(trigger_eligible -> canary_failover) when risk <= policy.max_blast_radius and capacity_ok

transition(canary_failover -> monitoring) when orchestrator ACKs initial actions

transition(monitoring -> promote_or_hold) when convergence_window elapsed

transition(promote_or_hold -> success) when health >= thresholds and SLOs restored

transition(promote_or_hold -> rollback_initiated) when health worsens or negative deltas exceed theta_worsen

transition(rollback_initiated -> rolling_back) start revert steps

transition(rolling_back -> closed) when restored to pre-state

transition(any -> contestation_workflow) on FailoverContestation open or stakeholder_disagreement_score >= 0.5

transition(* -> failed) on validation error/timeouts

timeout(monitored, convergence_window) -> rollback_initiated

idempotency_key = sha256(action_id, step_id, status)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 FailoverEvent	Required	Always	Authoritative failover decision & plan
OC-2 RollbackTrace	Conditionally Required	Any rollback executed	Assured reconstitution traceability
OC-3 IRFailoverIncidentLink	Optional	IR/SIEM integration present	Incident case traceability
OC-4 CanaryPromotionDecision	Conditionally Required	Canary workflow enabled	Safe promotion control
OC-5 FailoverContestation	Optional	Contestability enabled	Governance/appeals workflow
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment

- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: CP-10 (Recovery), CP-2, CP-7, SC-5
- **HITL required:** cross-region/global DNS cutover; promotion beyond max_blast_radius; override of cooldown; success declaration with unmet SLOs
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5
- **Manual outside agent:** extended degraded-mode approvals; customer/executive comms

SLOs and KPIs [Informative]

- DetectionToAction_p95 <= 60 s
- FlapSuppressionEffectiveness_30d >= 95 percent (oscillations avoided after first failover)
- PostFailoverSLORecovery_p95 <= 10 min
- FalseFailoverRate_30d <= 1 percent
- EvidenceQuorumRate >= 99 percent (events with >= N sources)

Outputs index [Informative]

[OC-1 FailoverEvent], [OC-2 RollbackTrace], [OC-3 IRFailoverIncidentLink], [OC-4 CanaryPromotionDecision], [OC-5 FailoverContestation], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (H4) [Informative]

Model and training profile [Informative]

model_id=failover-automation-text-model; temperature=0.1; max_tokens_out=700
 prompt_pack_id=failover-auto-v1 (quorum, cooldown, canary-first, rollback-first)
 RAG: sources={health-stream specs, SLO catalogs, incident histories, capacity maps, DR plans}; max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; evaluate on decision reproducibility and

hallucination bounds

guardrails: deny direct infra mutations; emit events only; require evidence quorum

Memory and state [Informative]

working_memory.max_tokens=3k; eviction=recency_then_importance

episodic_memory: per mission_id journal (signals, decisions, outcomes), ttl=365d

semantic_memory: namespaces=["services","regions","incidents","dr-plans"];

embeddings=text-embedding-sec-v1; k=10

durable_state_store: event-sourced ledger; snapshot at success/closed

consistency: at-least-once (events); consumer enforces exactly-once via

idempotency_key

idempotency: per Output Contracts

Decision and routing logic [Informative]

$$\begin{aligned} \text{failover_trigger_score} = & 0.35 * \text{slo_breach_intensity} + 0.25 * \text{hc_unhealthy_ratio} + \\ & 0.20 * \text{consecutive_failures_norm} + 0.10 * \text{region_capacity_risk} + \\ & 0.10 * (1 - \text{confidence_penalty}) \end{aligned}$$

eligible = (evidence_sources >= min_evidence_sources) and

(failover_trigger_score >= theta_trigger) and

cooldown_satisfied = true

promotion_decision = promote if health_convergence >= theta_converge and
error_rate_trend_down=true

rollback_decision = rollback if (health_convergence < theta_min) or worsen_delta >= theta_worsen

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial, jailbreak]

thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly ATT&CK/D3FEND-flavored prompts (e.g., forged

evidence_refs, prompt-injection to skip cooldown)

rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

decision_rationale_template: inputs (HC, SLO), quorum, scores, constraints, plan, rollback; hashes and attestations
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRFailoverIncidentLink (OC-3) when mission_link_refs present; attach FailoverEvent and subsequent RollbackTrace

Change Impact Assessment [Informative]

n/a (covered by DR governance); capture false-failover learnings to adjust thresholds (via feedback events)

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6); governance-reviewed updates may refine prompt_pack thresholds; never auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region=<us|eu|...>; enforce at ingress/egress
legal_hold=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: Health Check Streams; Telemetry/SLO Signals
Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as used)

Safety and abuse prevention [Informative]

kill_switch on attestation or signature mismatch; safe hold on repeated NACKs; cap promotions per service per hour; enforce cooldown strictly

Testing and validation [Informative]

contract tests for all OC schemas; offline replay of historic outages; flap-simulation drills; red-team forged-signal scenarios; drift checks and rollback

Deployment and lifecycle [Informative]

scale on queue depth; canary via synthetic failovers in staging; auto-rollback on validation failures; SBOM + attestations; sign outputs

References / Standards [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

MCP-Native Protocol Specification (H4) [Normative]

- **Native Protocol(s) Consumed:** Health Check Streams (LB/DNS/Service Registry); Telemetry/SLO Signals (OpenTelemetry/Monitoring REST)
- **Native Protocol(s) Produced:** FailoverEvent (Kafka/AMQP/REST); RollbackTrace (Kafka/AMQP/REST); CanaryPromotionDecision (Kafka/AMQP/REST, conditional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="FailoverAutomationAgent"; intent="recover"; decision_basis (evidence_refs from at least N distinct sources, confidence, explanation_ref); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** constraints; policy_refs; classification; legal_hold; mission_link_refs
- **Enforcement Note:** PEP/orchestrator components must verify provenance.attestation and enforce constraints including min_evidence_sources, cooldown_seconds, region and blast-radius limits; production/global cutovers require HITL/CAB/IR gates.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native + MCP-wrapped examples as above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

H5. Immutable Backup Agent

Agent Blueprint [Informative]

Purpose: Enforce and verify untamperable, encrypted backups and periodic restore tests; emit attested **BackupSnapshot** and **RestoreTestResult** artifacts suitable for audit/regulatory evidence.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Backup Jobs (Scheduler/Orchestrator REST/JSON):** job id, scope, schedule, retention, storage config (immutability mode, versioning, checksums), encryption (KMS key, algorithm), verification cadence and target env, airgap copy policy, owners.
- **KMS/HSM State (KMS REST/gRPC):** key origin (HSM), rotation status and interval, policy digest, grants, FIPS mode, last_rotated timestamp.

Model training / knowledge (what the LLM relies on):

- Prompt pack: “immutable-backup-rubric” (required retention, compliance/governance immutability rules, encryption posture checks, restore-test evidence requirements).
- RAG: backup job catalog, storage control-plane docs for immutability features (e.g., Object Lock compliance mode), KMS policies, prior RestoreTestResult reports; dereference sensitive content via evidence_refs (do not train on data payloads).
- Guardrails: deny modifications that reduce retention below policy; forbid disabling immutability or changing KMS to non-HSM origins; function access limited to read-only job inspection and emitting signed artifacts; changes to job definitions require HITL.

Decisions it makes (deterministic + model-assisted):

- **Policy compliance evaluation:** verify retention $\geq$ minimum, immutability in compliance mode, versioning on, checksum algorithm meets policy, airgap enabled if required, KMS in FIPS/HSM and rotation interval within threshold.
- **Snapshot attestation:** gather control-plane proofs (e.g., write-once flags, legal hold), compute checksums, record storage location and retention end date, sign provenance.

- **Restore-test orchestration (read-only to data plane):** launch scheduled restore in restore-sandbox, verify integrity (checksums/logical checks), measure RTO/RPO alignment, collect telemetry, and emit **RestoreTestResult**.
- **Exception routing:** if any required control fails (e.g., immutability not in compliance mode, expired keys), emit violation event and open ticket; may freeze job changes until remediated.
- **Legal hold honoring:** elevate classification, extend retention, and block purge when `legal_hold=true`.

Routing / where outputs go:

- **BackupSnapshot** → Kafka/AMQP/REST to governance dashboards, evidence store, and GRC mapping.
- **RestoreTestResult** → same event bus and evidence store; link to test run logs and checksums.
- **IR/ITSM** → optional violation events (e.g., immutability disabled) with case links.

Automation scope vs. manual/HITL:

- Fully automated: compliance evaluation, snapshot attestation, checksum verification, scheduled restore tests in sandbox, evidence capture, signed artifact emission.
- **HITL required:** configuration changes that reduce retention/immutability; rotation override; restore tests touching production data or crossing regions with egress fees/risk; decrypt-and-validate flows requiring sensitive data handling.
- Manual outside agent: business acceptance of retention cost increases; regulatory liaison for long-term legal hold extension.

Security Domain: Resilience, Continuity, and Recovery

Inputs (native protocols consumed) [Informative]

1. **Backup Jobs (Scheduler/Orchestrator REST/JSON)** — job definitions, schedules, targets, retention, verification.
2. **KMS/HSM State (KMS REST/gRPC)** — key status/rotation, policy digest, FIPS/HSM provenance.

Example: Consumed Protocol — Backup Jobs (Scheduler/Orchestrator REST/JSON) [Informative]

Native payload

```
{
  "job_id": "bk-payments-daily",
  "service": "payments-api",
  "scope": { "type": "database_cluster", "resources": ["aurora:payments-prod"] },
  "schedule_cron": "0 2 * * *",
  "retention_days": 45,
  "storage": {
    "bucket": "backup-vault-prod",
    "immutability": { "mode": "compliance", "retain_until_days": 45 },
    "versioning": true,
    "checksum": "sha256"
  },
  "encryption": { "kms_key_id": "kms-arn-1234", "algorithm": "AES-256-GCM" },
  "verification": { "type": "logical_checksum_and_restore-test", "frequency_days": 7,
"target_env": "restore-sandbox" },
  "airgap_copy": { "enabled": true, "vault": "backup-tape-airgap", "rpo_hours": 24 },
  "owners": ["payments.sre"],
  "last_updated": "2025-08-10T18:55:00Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h5-bk-1111-2222-3333-4444",
    "thread_id": "uuid-job-bk-payments-daily",
```

```

"task_id": "uuid-aa11-bb22-cc33-dd44",
"role": "ImmutableBackupAgent",
"intent": "preserve",
"policy_refs": ["CP-9", "CP-10", "SC-12", "SC-13"],
"constraints":
["retention_min_days:30","immutability:compliance_mode","airgap_required:true","chec
ksum:sha256","no_overwrite:true"],
"decision_basis": {
  "evidence_refs": ["uri://backup/jobs/bk-payments-daily@2025-08-10"],
  "confidence": 0.98,
  "explanation_ref": "uri://kb/backup/immutable-job-controls"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/resilience/immutable-backup-agent",
  "signing_kid": "kid-backup-h5-01",
  "attestation_ref": "uri://attest/backup/immutability/storage-
controlplane@sha256:bk01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — KMS/HSM State (KMS REST/gRPC) [Informative]
Native payload

```

{
  "key_id": "kms-arn-1234",
  "alias": "alias/backup-prod",

```

```

"state": "Enabled",
"key_usage": "ENCRYPT_DECRYPT",
"key_spec": "AES_256",
"origin": "HSM",
"rotation_enabled": true,
"rotation_interval_days": 365,
"policy_digest_sha256": "c9b1c7e6d4f5...",
"last_rotated": "2025-05-01T00:00:00Z",
"grants": ["backup-service-role", "restore-auditor-role"],
"fips_mode": true,
"created": "2023-02-17T10:12:00Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-h5-kms-5555-6666-7777-8888",
    "thread_id": "uuid-kms-kms-arn-1234",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "ImmutableBackupAgent",
    "intent": "preserve",
    "policy_refs": ["SC-12", "SC-13", "CP-9"],
    "constraints": ["rotation<=365d", "fips_required:true"],
    "decision_basis": {
      "evidence_refs": ["uri://kms/keys/kms-arn-1234/describe@2025-08-15"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/backup/kms-encryption-and-rotation"
    }
  }
}

```

```

},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/resilience/immutable-backup-agent",
  "signing_kid": "kid-kms-h5-02",
  "attestation_ref": "uri://attest/backup/immutability/kms-hsm-
provenance@sha256:kms02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **BackupSnapshot** (Kafka/AMQP/REST) — snapshot metadata, retention/immutability flags, checksums, storage proofs, provenance.
- **RestoreTestResult** (Kafka/AMQP/REST) — restore verification outcome, metrics, RTO/RPO measurement, evidence URIs.

MCP context (required) [Informative]

mission_id; role="ImmutableBackupAgent"; intent="preserve"; policy_refs (CP-9, CP-10, SC-12, SC-13); decision_basis (evidence_refs to job config, storage control-plane results, KMS state; confidence; explanation_ref); provenance (SPIFFE ID, signing KID, attestation_ref for immutability compliance)

MCP context (optional) [Informative]

constraints (e.g., "retention_min_days:30","immutability:compliance_mode","airgap_required:true","checksum:sha256","no_overwrite:true"); classification (C2 default; C3 if data paths include customer identifiers); legal_hold; mission_link_refs to incident/case.

Enforcement note [Informative]

PEPs must verify provenance.attestation, immutability flags (e.g., Object Lock compliance mode), retention targets, checksum algorithm, and KMS FIPS/HSM

provenance before accepting artifacts; job-definition changes that reduce protections require HITL.

NIST SP 800-160v2 linkage [Informative]

Maintain & Recover — assured preservation and reconstitution via tamper-resistant, verifiably encrypted backups with auditable restores.

Automation feasibility [Informative]

High (evaluation, enforcement, verification, attestations are automatable; restore tests scheduled per job policy).

Output Contracts (merged) [Informative]

OC-1: BackupSnapshot (Attested Snapshot) [Informative]

- **Producer(s):** H5
- **Topic/Path:** resilience.backup.snapshot (Kafka/AMQP) or POST /backup/snapshots (REST)
- **Schema/Format:** BackupSnapshot@1.0 (mission_id, job_id, resource_scope, snapshot_id, created_ts, storage_uri, retention_until, immutability_mode, versioning, checksum_alg, checksum_value, kms_key_id, kms_origin, fips_mode, evidence_refs[], provenance, classification_label)
- **Classification:** C2 (C3 if data-path identifiers present)
- **Delivery:** at-least-once
- **Ordering:** per job_id then snapshot_id
- **Idempotency-Key:** sha256(job_id, snapshot_id, checksum_value)
- **Ack/Nack:** broker ACK<=5s or REST 201; NACK=4xx/5xx
- **Timeouts/Retry:** exp-backoff<=5x; on failure open ticket and persist local claim
- **Side-Effects:** write JSONL record to evidence store; update GRC evidence map
- **HITL Token:** none (reporting-only)
- **Observability:** trace_id, mission_id, job_id, snapshot_id, provenance.attestation
- **Retention/TTL:** match retention_until; override on legal_hold=true

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=BackupSnapshot@1.0 | json_schema_uri=uri://schema/backup-snapshot-1.0.json | sha256= | producers=H5 | consumers=GovDash-01, Audit-01, GRC-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: RestoreTestResult (Attested Restore Verification) [Informative]

- **Producer(s):** H5
- **Topic/Path:** resilience.backup.restore_result (Kafka/AMQP) or POST /backup/restore-tests (REST)
- **Schema/Format:** RestoreTestResult@1.0 (mission_id, job_id, test_id, snapshot_ref, target_env, start_ts, end_ts, verification_type, integrity_ok, checksum_match, rto_minutes_measured, rpo_minutes_measured, anomalies[], evidence_refs[], provenance)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per job_id then test_id
- **Idempotency-Key:** sha256(job_id, test_id, snapshot_ref)
- **Ack/Nack:** broker ACK<=5s or REST 201; NACK=4xx/5xx
- **Timeouts/Retry:** exp-backoff<=5x; open ticket if repeated failures
- **Side-Effects:** update compliance dashboard; create ticket on integrity_ok=false
- **HITL Token:** required if test touches production data or cross-region restores
- **Observability:** trace_id, mission_id, job_id, test_id
- **Retention/TTL:** 7 years (regulatory evidence)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When verification/restore-test is enabled by policy or job config

schema_id=RestoreTestResult@1.0 | json_schema_uri=uri://schema/restore-test-result-1.0.json | sha256= | producers=H5 | consumers=GovDash-01, Audit-01, IR-Case-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: IRBackupViolationEvent (IR Integration) [Informative, optional]

- **Producer(s):** H5
- **Topic/Path:** resilience.backup.violation
- **Schema/Format:** IRBackupViolationEvent@1.0
(violation_type={immutability_off, retention_below_min, kms_non_hsm, checksum_mismatch}, job_id, snapshot_ref?, severity, incident_id?, evidence_refs[])
- **Classification:** C2
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(job_id, violation_type, snapshot_ref?)
- **Ack/Nack:** IR case id <=30s; retry/backoff
- **Side-Effects:** open SOAR/IR case; apply policy freeze if severity=high
- **Observability:** trace_id, mission_id, incident_id
- **Retention/TTL:** per IR policy

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRBackupViolationEvent@1.0 | json_schema_uri=uri://schema/ir-backup-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: KeyRotationAttestation (Crypto Posture Proof) [Informative]

- **Producer(s):** H5
- **Topic/Path:** resilience.backup.kms_attestation
- **Schema/Format:** KeyRotationAttestation@1.0 (kms_key_id, rotation_enabled, rotation_interval_days, last_rotated, fips_mode, origin=HSM, policy_digest_sha256, evidence_refs[], provenance)
- **Classification:** C2
- **Delivery:** at-least-once

- **Ordering:** per kms_key_id
- **Idempotency-Key:** sha256(kms_key_id, last_rotated, policy_digest_sha256)
- **Ack/Nack:** broker ACK or REST 201
- **Side-Effects:** link to BackupSnapshot/RestoreTestResult records
- **HITL Token:** none
- **Observability:** trace_id, mission_id, kms_key_id
- **Retention/TTL:** 7 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When enterprise policy mandates crypto posture attestation for backup keys
 schema_id=KeyRotationAttestation@1.0 | json_schema_uri=uri://schema/key-rotation-attestation-1.0.json

Conformance: Normative when condition is met.

OC-5: BackupContestation (Explainability & Appeals) [Informative, optional]

- **Producer(s):** H5, Legal-Portal-01, Compliance-Portal-01
- **Topic/Path:** resilience.backup.contestation
- **Schema/Format:** BackupContestation@1.0 (dispute_type={retention, immutability, crypto, restore_result}, rationale_url, severity, job_id, snapshot_ref?)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(job_id, snapshot_ref?, dispute_id)
- **Ack/Nack:** case_id <=30s; retry/backoff
- **Side-Effects:** freeze policy-lowering changes; require HITL for restores until resolved
- **HITL Token:** required when severity >= high
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=BackupContestation@1.0 | json_schema_uri=uri://schema/backup-contestation-1.0.json

Conformance: Normative if implemented or claimed.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; H5 (aggregation)
- **Topic/Path:** resilience.backup.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (review_id, job_id, artifact_ref, labels={helpful|neutral|harmful}, notes)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once
- **Idempotency-Key:** sha256(review_id, artifact_ref)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** add to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, job_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, evaluating_job, enforcing_policy, snapshotting, verifying_snapshot, restore_testing, success, contestation_workflow, failed, closed }

transition(idle -> evaluating_job) on job_updated or schedule_tick

transition(evaluating_job -> enforcing_policy) when gaps detected or attestations due

transition(enforcing_policy -> snapshotting) when configuration validated

transition(snapshotting -> verifying_snapshot) after checksum/immutability proofs collected

transition(verifying_snapshot -> restore_testing) when verification cadence window opens

transition(restore_testing -> success) when integrity_ok=true and RTO/RPO within thresholds

transition(any -> contestation_workflow) when BackupContestation opens or stakeholder_disagreement_score >= 0.5

transition(* -> failed) on validation error, checksum_mismatch, or immutability_off

timeout(restore_testing, timebox_minutes) -> failed

idempotency_key = sha256(job_id, snapshot_id|test_id, status)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 BackupSnapshot	Required	Always	Core evidence of protected backups
OC-2 RestoreTestResult	Conditionally Required	Verification/restore testing enabled by policy or job	Assured recoverability evidence
OC-3 IRBackupViolationEvent	Optional	IR/SIEM integration present	Rapid incident response on violations
OC-4 KeyRotationAttestation	Conditionally Required	Crypto posture attestation mandated by enterprise policy	Cryptographic assurance for auditors

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-5 BackupContestation	Optional	Contestability enabled	Governance and appeals workflow
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** CP-9 Information System Backup; CP-10 System Recovery; SC-12/SC-13 Cryptographic Protection (plus local backup governance).
- **HITL required:** any reduction of retention/immutability; key rotation overrides; restore tests that touch production data or bypass airgap; decrypt-and-validate procedures.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5; repeated checksum_mismatch.
- **Manual outside agent:** regulatory exception handling; cross-border data transfer approvals.

SLOs and KPIs [Informative]

- SnapshotAttestAck_p95 <= 60 s
- RestoreTestSuccessRate_30d >= 95 percent
- ChecksumMismatchRate_30d <= 0.5 percent
- CryptoPostureDriftMTTD <= 24 h
- EvidenceCompletenessRate >= 99 percent

Outputs index [Informative]

[OC-1 BackupSnapshot], [OC-2 RestoreTestResult], [OC-3 IRBackupViolationEvent], [OC-4 KeyRotationAttestation], [OC-5 BackupContestation], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (H5) [Informative]

Model and training profile [Informative]

model_id=immutable-backup-text-model; temperature=0.1; max_tokens_out=800
prompt_pack_id=immutable-backup-v1 (retention, immutability, crypto posture, restore-test rubric)

RAG: sources={backup job catalog, storage immutability docs, KMS key registry, past restore reports}; max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; evaluate on policy-check accuracy and hallucination bounds

guardrails: forbid emitting actions that change protection posture; emit artifacts only;
require evidence_refs for all decisions

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance

episodic_memory: per mission_id journal (jobs, snapshots, restores, violations),
ttl=365d

semantic_memory: namespaces=["backup-jobs", "kms", "storage-proofs", "restore-reports"]; embeddings=text-embedding-sec-v1; k=10

durable_state_store: event-sourced ledger; snapshot after each

BackupSnapshot/RestoreTestResult

consistency: at-least-once for events; consumer-side exactly-once via idempotency_key

idempotency: per Output Contracts

Decision and routing logic [Informative]

immutability_score = 0.4*mode_compliance_flag + 0.2*versioning_on +
0.2*legal_hold_capable + 0.2*no_overwrite_flag

crypto_posture_score = 0.5*(origin_is_HSM and fips_mode) +
0.3*(rotation_interval_days <= policy.max_days) +
0.2*policy_hash_match

$$\text{backup_risk_score} = 0.5 \cdot (1 - \text{immutability_score}) +$$
$$0.3 \cdot (1 - \text{crypto_posture_score}) +$$
$$0.2 \cdot (\text{retention_gap_norm})$$

`require_HITL = backup_risk_score >= theta_human`

Model Risk Management [Informative]

`continuous_validation`: daily; `eval_suite`=[goldens, adversarial, jailbreak]
`thresholds`: `eval_pass_rate` >= 99.5 percent → `auto_HITL` if below
`red_team_cycle`: monthly attacks (forged proofs, prompt-injection to accept
`governance_mode` over `compliance_mode`)
`rollback_policy`: `eval_drop` >= 1.5 percentage points for 48 h → `revert model_id`; notify
owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

`decision_rationale_template`: who, what, why; retention, immutability, crypto posture,
restore metrics; hashes and attestations
UI/API: expose `classification_label`, `provenance.attestation`, `decision_rationale_url`
`audit_log_format`: JSONL with stable field order; retention per classification and
`legal_hold`

Incident Response Integration [Informative]

emit `IRBackupViolationEvent` (OC-3) for high-severity gaps; attach relevant
`BackupSnapshot/RestoreTestResult`

Change Impact Assessment [Informative]

n/a (policy-governed); track trends from failed restores and checksum mismatches to
inform job changes (HITL)

Stakeholder Feedback Loop [Informative]

emit `FeedbackIngestionEvent` (OC-6); govern incorporation into `prompt_pack`; never
auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

`data_locality_policy`: `region`=<us|eu|...>; enforce at ingress/egress
`legal_hold`=true → override TTL; block purge; tag audit entries

Interfaces (links only) [Informative]

Consumes: Backup Jobs (Scheduler/Orchestrator REST/JSON); KMS/HSM State (REST/gRPC)

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6 (as used)

Safety and abuse prevention [Informative]

kill_switch on attestation/signature mismatch; refuse to attest snapshots with non-compliance immutability; cap evidence fetch rate; sandbox restore tests

Testing and validation [Informative]

contract tests for OC schemas; offline replay of historical snapshots/restores; adversarial forged-proof tests; drift checks and rollback

Deployment and lifecycle [Informative]

scale on job volume; canary per service; auto-rollback on validation failures; SBOM and attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-34; NIST SP 800-53 Rev. 5 (CP-9/CP-10; SC-12/SC-13); NIST CSF 2.0; ISO 22301:2019; MITRE D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (H5) [Normative]

- **Native Protocol(s) Consumed:** Backup Jobs (Scheduler/Orchestrator REST/JSON); KMS/HSM State (KMS REST/gRPC)
- **Native Protocol(s) Produced:** BackupSnapshot (Kafka/AMQP/REST); RestoreTestResult (Kafka/AMQP/REST); KeyRotationAttestation (Kafka/AMQP/REST, conditional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="ImmutableBackupAgent"; intent="preserve"; policy_refs; decision_basis (evidence_refs to job config, storage control-plane results, KMS state; confidence; explanation_ref); provenance (SPIFFE ID, signing KID, attestation_ref)
 - **Optional:** constraints; classification; legal_hold; mission_link_refs
- **Enforcement Note:** PEPs must verify provenance.attestation and ensure immutability mode, retention_min_days, checksum algorithm, and KMS

FIPS/HSM provenance before accepting artifacts; any protection-lowering change requires HITL.

- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native and MCP-wrapped examples as provided above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.